

1. Schriftliche Wiederholung **Konsolidierte Folien**

IT-SICHERHEIT / SEMESTER 1



1

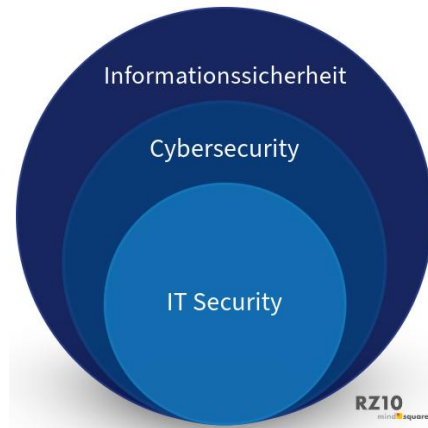
01

Einführung

2

IT-SICHERHEIT / SEMESTER 1 UND 2

In a Nutshell



tgm

[Quelle: <https://rz10.de/it-security/it-security-vs-cybersecurity/> - letzter Abruf 04.09.2025]

tgm | Technologisches Gewerbemuseum | Höhere technische Bundes-Lehr- und Versuchsanstalt

3

3

IT-Sicherheit

4

Was ist IT-Sicherheit

- (1) „Informationen sowie informationsverarbeitende Systeme, Komponenten und Prozesse **sind besonders schützenswert**.
- (2) Der **Zugriff** auf diese darf ausschließlich durch **autorisierte Personen oder Programme** erfolgen.
- (3) Die Sicherheit in der Informationstechnik und der damit verbundene Schutz von Informationen und informationsverarbeitenden Systemen **vor Angriffen und unautorisierten Zugriffen** im Sinne dieses Gesetzes erfordert die **Einhaltung bestimmter Sicherheitsstandards** zur Gewährleistung der informationstechnischen Grundwerte und Schutzziele.
- (4) Sicherheit in der Informationstechnik ... bedeutet die **Einhaltung bestimmter Sicherheitsstandards, die die Verfügbarkeit, Integrität oder Vertraulichkeit von Informationen** betreffen, durch Sicherheitsvorkehrungen
1. in **informationstechnischen Systemen, Komponenten oder Prozessen** oder
 2. bei der **Anwendung von informationstechnischen Systemen, Komponenten oder Prozessen**.“

§ 2 Abs. 2 BSI-Gesetz (BGBI. I S. 2821, zuletzt geändert durch Art. 1 des Gesetzes vom 18. Mai 2021 (BGBI. I S. 1122))

Informationstechnische Systeme

Informationstechnische Systeme sind technische Anlagen, »**die der Informationsverarbeitung dienen und eine abgeschlossene Funktionseinheit bilden**.

Typische IT-Systeme sind **Server, Clients, Einzelplatzcomputer, Mobiltelefone, Router, Switches und Sicherheitsgateways**.«

Sicherheitsstandards

- In der IT-Sicherheit **müssen Sicherheitsstandards eingehalten werden**, das heißt, ohne Sicherheitsstandards, also ohne Vorgaben, gibt es keine Informationssicherheit.
- Durch die Sicherheitsstandards wird der **Soll-Zustand vorgegeben. Abweichungen des Ist-Zustands vom Soll-Zustand werden als Sicherheitsvorfälle bezeichnet.**
- Der Begriff Standard ist hier nicht nur im Sinne von
 - ISO-Standards
 - DIN-Normen
- zu verstehen.
- Jede Passwortrichtlinie und jede Nutzerordnung in Ihrem Unternehmen oder Ihrer Behörde ist ein interner Sicherheitsstandard im Sinne einer solchen Vorgabe.

Sicherheitsmaßnahmen (ein analoger Vergleich)

Sicherheitsmaßnahmen in den Systemen (Nummer 1) und bei der Nutzung der Systeme (Nummer 2) getroffen werden.

Situation:

- Stellen Sie sich ein Bürogebäude vor, in dem die Türen keine Schlösser haben. Die Türen stehen ständig offen und die auf den Schreibtischen liegenden **Dokumente sind dem Zugriff Unbefugter ausgesetzt**, wenn ein Beschäftigter das Büro verlassen hat.

Maßnahme:

- Sicherheit erhöhen und deswegen einbauen von **Schlössern** in die Türen. Das Ergebnis ist aber, dass trotz eingebauter Schlösser die Türen ständig offenstehen.
- Daraufhin zusätzlich eine Dienstanweisung, dass beim Verlassen des Büros die Bürotür abgeschlossen werden muss.

Ergebnis:

- Die **technische Maßnahme** »Schloss« allein löste das Problem nicht. Erst die ergänzende organisatorische Maßnahme
- „**Dienstanweisung**“ über den Umgang mit dem Schloss schafft den gewünschten Erfolg.
- Da sich nicht alle Beschäftigten zu 100 Prozent an die Dienstanweisung halten, müssen **zusätzlich regelmäßige Kontrollen** die Regeleinhaltung sicherstellen.

Was fällt alles unter IT Sicherheit?

- IT-Sicherheit, ein Subfeld der Informationssicherheit, konzentriert sich speziell auf **elektronisch gespeicherte Informationen und IT-Systeme**.
- Ihr Kerngebiet umfasst den **Schutz vor Bedrohungen** wie Hackerangriffen, Spionage und unbefugtem Datenzugriff.
- Die IT-Sicherheit greift ebenfalls auf die CIA-Triade zurück, fokussiert sich jedoch stärker auf **digitale Aspekte**.
- Sie ist breit gefächert und beinhaltet den Schutz vor **internen und externen Bedrohungen**.

Dimensionen der Sicherheit:

- **Physische Sicherheit:** Diese betrifft den Schutz physischer Systeme und Hardware.
- **Technische Sicherheit:** Sie fokussiert sich auf die Sicherung von Daten, die innerhalb eines Netzwerks gespeichert oder übertragen werden.
- **Administrative Sicherheit:** Diese beinhaltet die Entwicklung und Umsetzung von Richtlinien und Prozessen zur Nutzerkontrolle im Netzwerk.

Was fällt alles unter IT Sicherheit?

- **Firewalls:** Schutz vor unautorisiertem Zugriff.
- **Antivirenprogramme:** Erkennung und Entfernung von Schadsoftware.
- **Verschlüsselung:** Schutz sensibler Daten durch Umwandlung in unlesbare Form.
- **Passwortmanagement:** Sichere Verwaltung und Erstellung starker Passwörter.
- **Sicherheitupdates:** Regelmäßige Aktualisierungen von Software, um Sicherheitslücken zu schließen.
- **Netzwerksicherheit:** Schutz von Netzwerken vor Angriffen.
- **Backup und Recovery:** Erstellung von Sicherungskopien und Wiederherstellungsplänen.
- **Zugriffskontrolle:** Beschränkung des Zugriffs auf sensible Informationen.
- **Schulung und Sensibilisierung:** Schulung der Mitarbeiter in Sicherheitsfragen.

Cybersicherheit

11

IT-SICHERHEIT / SEMESTER 1 UND 2

Was bedeutet „Cyberraum“?

Der „Cyberraum“ oder auch der „Cyber- und Informationsraum“ beschreibt als Sammelbegriff

- die **gesamte digital vernetzte Welt**: also das weltumspannende Internet mit all seinen Facetten – inklusive des Darknets, eines verborgenen Teils des Internets, der nur mit spezieller Software zugänglich ist.
- Alle Bedrohungen, die aus dem Cyberraum kommen, sind **Cyberangriffe**
- und der Schutz vor diesen Bedrohungen und die Abwehr solcher Angriffe machen die **Cybersicherheit** aus.

12

Was ist Cybersicherheit

„Cybersicherheit“ bezeichnet **alle Tätigkeiten, die notwendig sind, um Netz- und Informationssysteme, die Nutzer solcher Systeme und andere von Cyberbedrohungen betroffene Personen zu schützen;**

„Cyberbedrohung“ bezeichnet **einen möglichen Umstand, ein mögliches Ereignis oder eine mögliche Handlung, der/das/die Netz- und Informationssysteme, die Nutzer dieser Systeme und andere Personen schädigen, stören oder anderweitig beeinträchtigen könnte;**«

Art. 2 Nr. 1 und Nr. 8 Rechtsakt zur Cybersicherheit, ABl. L 151 vom 7.6.2019, S. 15–69

Was ist Cybersicherheit?

- Cybersicherheit, **oft als das modernste Feld** betrachtet, erweitert den Fokus der IT-Sicherheit auf das **gesamte Internet** und alle Netzwerke.
- Dies beinhaltet die Sicherheit **aller über Netzwerke verbundenen Systeme und Daten, einschließlich kritischer Infrastrukturen** wie Stromversorgung und Telekommunikation.
- Cybersicherheit ist somit nicht **nur auf einzelne Unternehmen beschränkt**, sondern betrachtet die **Gesamtheit** der vernetzten digitalen Welt.
- Konzentriert sich auf die Abwehr von **Bedrohungen, die direkt aus dem Cyberspace stammen**, wie Cyberkriminalität, Angriffe und Betrug.

Zu den **Hauptaufgaben** gehören:

- Schutz der **elektronischen Kommunikation**.
- Prävention und **Wiederherstellung** von Schäden an digitalen Systemen.
- Fokus auf **Online-Daten** und deren Sicherheit.

Verschiedene Blickwinkel auf Cybersicherheit?

- **Privatanwender:** Persönliche Daten sind nur für einen selbst und für Personen zugänglich, die über eine entsprechende Berechtigung verfügen. Alle Computer und computerähnlichen Geräte funktionieren korrekt und sind frei von Malware.
- **Geschäftsinhaber:** Die Daten von Kredit- und Bankkarten sind angemessen geschützt und Sicherheitsstandards werden an der Kasse eingehalten.
- **Online-Händler:** Die Server, mit denen nicht vertrauenswürdige Außenstehende laufend interagieren, sind angemessen geschützt.
- **Anbieter von Shared Services:** Mehrere Datenzentren mit einer großen Anzahl von Servern mit wiederum vielen virtuellen Servern verschiedener Unternehmen müssen gegen Angriffe verteidigt werden.
- **Staat:** Daten werden klassifiziert und jede Kategorie unterliegt bestimmten Gesetzen, Regelungen, Verfahren und Technologien.

Treiber für Cybersicherheit?

- | | |
|--|--|
| <ul style="list-style-type: none"> ▪ Technologischer Wandel ▪ Digitale Daten ▪ Das Internet und Kryptowährungen ▪ Mobiles arbeiten und Fernzugriff ▪ Smarte Geräte ▪ Big Data ▪ Gesellschaftlicher Wandel ▪ Wandel von Geschäftsmodellen ▪ Politischer Wandel ▪ Datensammlung ▪ Wahlbeeinflussung | <ul style="list-style-type: none"> ▪ Hacktivismus und mehr Freiheiten ▪ Sanktionen ▪ Neue Machtverhältnisse |
|--|--|



Cybercrime

Cyberkriminalität bezieht sich auf illegale Machenschaften unter Einsatz von Computern oder dem Internet.

Cyberkriminalität wird in folgende Hauptkategorien unterteilt:

Angriffe auf Personen:

- Identitätsdiebstahl
- Cybermobbing und Stalking
- Kreditkartenbetrug
- Ausspähen von Daten
- Verbreitung von Kinderpornographie

Angriffe auf Eigentum:

- DDoS-Angriffe

- Installation von Viren auf Computern

- Urheberrechtsverletzungen

Angriffe auf Behörden und Regierungen:

- Eindringen in fremde Netzwerke (Hacking)
- Cyberterrorismus oder Verbreitung von Propaganda
- Volksverhetzung

Cyberangriff Methoden - Welche Attacken gibt es?

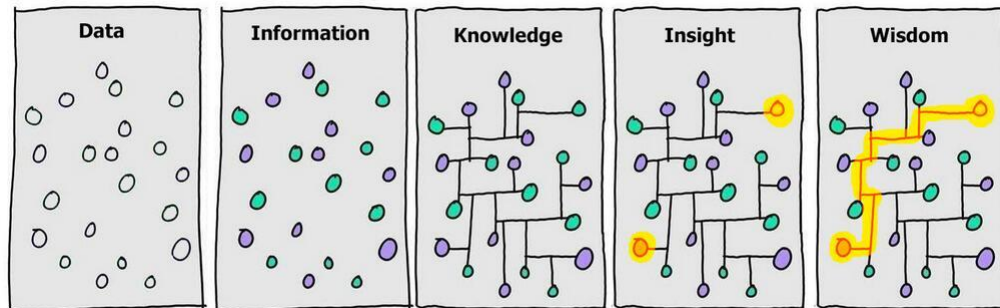
- **Phishing:** Betrügerische E-Mails oder Webseiten, die darauf abzielen, persönliche Daten zu stehlen.
- **Malware:** Schadsoftware, die Systeme infiziert und Daten stiehlt oder beschädigt.
- **Ransomware:** Verschlüsselt Daten und fordert Lösegeld für die Entschlüsselung.
- **DDoS-Angriffe:** Überlastung eines Servers durch massenhafte Anfragen, um diesen lahmzulegen.
- **Man-in-the-Middle-Angriffe:** Abfangen und Manipulieren von Kommunikation zwischen zwei Parteien.
- **SQL-Injektionen:** Einschleusen von schädlichem Code in Datenbanken über unsichere Eingabefelder.

Wichtige Richtlinien und Leitlinien

- **Passwort-Richtlinien:** Verwenden Sie starke Passwörter und ändern Sie diese regelmäßig. Vermeiden Sie einfache Passwörter wie "123456" oder "Passwort".
- **Zugriffskontrollen:** Stellen Sie sicher, dass nur autorisierte Personen Zugriff auf sensible Daten haben. Nutzen Sie rollenbasierte Zugriffskontrollen (RBAC).
- **Software-Updates:** Halten Sie alle Systeme und Anwendungen stets auf dem neuesten Stand, um Sicherheitslücken zu schließen.
- **Schulungen:** Bieten Sie regelmäßige Schulungen für Mitarbeiter an, um sie über aktuelle Bedrohungen und Best Practices zu informieren.
- **Datensicherung:** Führen Sie regelmäßige Backups durch und testen Sie die Wiederherstellbarkeit der Daten.
- **Netzwerksicherheit:** Implementieren Sie Firewalls, VPNs und Intrusion-Detection-Systeme (IDS), um Ihr Netzwerk zu schützen.
- **Notfallpläne:** Erstellen und pflegen Sie Notfallpläne für den Fall eines Sicherheitsvorfalls.

Daten und Information

Daten vs. Informationen



Beispiele für Daten

- **Rohe Zahlen:** Eine Art von Daten, die statistisch erfasst werden können, wie z. B. die Anzahl der Verkäufe, positive Bewertungen, Unternehmenseinnahmen und Kundenzahlen.
- **Text:** Eine Art von schriftlichen Daten, z. B. E-Mails, Beiträge und Produktbeschreibungen.
- **Bilder:** Eine Art von Daten, die mit Kameras aufgenommene Fotos, KI-gestützte Bilder oder in einer digitalen Umgebung erstellte visuelle Designs darstellen.
- **Audio und Video:** Aufzeichnungen, die Audio- oder Bildmaterial oder beides enthalten.

Beispiele für Informationen

Während Daten die rohe Form von Wissen sind, sind Informationen die verarbeitete, organisierte und strukturierte Form von Rohdaten.

Man fügt den Rohdaten einen Kontext hinzu und kategorisiert, verarbeitet, strukturiert oder organisiert die Daten in Übereinstimmung mit diesem Kontext und wandelt sie in Informationen um

→ Neues Wissen

- Berichte
- Zusammenfassungen
- Schaubilder
- Diagramme
- SOPs
- Leitfäden
- To-Do-Listen
- Rahmenwerke
- Anmerkungen zur Sitzung
- Umriss
- Produkt-Roadmaps

Datenschutz

Was ist Datenschutz?

- Datenschutz ist das **Recht einer Person, selbst zu entscheiden, wer wann welche persönlichen Daten erhält, speichert oder verarbeitet.**
- Er schützt **personenbezogene Daten** – also Informationen wie Name, Adresse oder E-Mail – vor Missbrauch und dient dem Schutz der Privatsphäre.
- Die **Datenschutz-Grundverordnung (DSGVO) und nationale Gesetze** regeln dies, um die informationelle Selbstbestimmung sicherzustellen.

Was sind personenbezogene Daten?

- Name, Adresse, Geburtsdatum
- E-Mail-Adresse und IP-Adresse
- Gesundheitsdaten, politische Meinung, sexuelle Orientierung: (besonders sensible Daten)

Zentrale Aspekte des Datenschutzes

- Informationelle Selbstbestimmung:
- Jeder Mensch hat das Recht, selbst zu bestimmen, wer welche Informationen über ihn erhält.

Rechtliche Grundlage:

Die Verarbeitung personenbezogener Daten muss auf einer rechtmäßigen Grundlage erfolgen.

Rechte der Betroffenen:

Bürger können Auskunft darüber verlangen, welche Daten gesammelt wurden, und bei unrechtmäßiger Sammlung die Löschung fordern.

Verantwortung der Unternehmen:

Organisationen müssen Datenschutzgesetze einhalten und ihre Praktiken offenlegen.



[Quelle: <https://dsb.gv.at/rechte-pflichten/was-ist-datenschutz> - letzter Abruf 04.09.2025]

tgm | Technologisches Gewerbemuseum | Höhere technische Bundes-Lehr- und Versuchsanstalt

25

25

Informationssicherheit

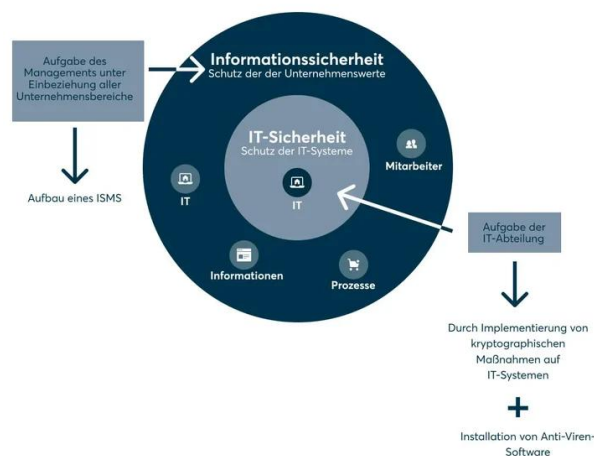
26

Was ist Informationssicherheit?

- Informationssicherheit ist der **Schutz von Informationen vor unberechtigtem Zugriff, Missbrauch, Verlust oder Veränderung**, um die Vertraulichkeit, Integrität und Verfügbarkeit von Informationen sicherzustellen.
- Zum Schutz ihrer Informationen und Daten **setzen Organisationen verschiedene Methoden und Techniken ein, die zusammen als „Informationssicherheit“ bezeichnet werden**. Dazu gehören auch Richtlinieneinstellungen zur Verhinderung unerwünschter Zugriffe auf geschäftliche oder persönliche Daten.
- Das Thema Informationssicherheit **wird immer komplexer und schließt verschiedenste Bereiche ein**, wie z. B. Netzwerk- und Infrastruktursicherheit sowie Prüfungen und Tests zur Sicherstellung der Wirksamkeit.
- Generell handelt es sich bei **Informationswerten um jede Art von (Vermögens-) Werten eines Unternehmens oder einer Organisation**. Dies kann von personenbezogenen Informationen bis zu immateriellen Werten wie die Reputation oder Ansehen sein.
- Unter dem Begriff „Informationssicherheit“ lassen sich folgende Bausteine gliedern:
 - Organisatorische
 - Physische
 - personelle
 - und technische Sicherheit.

27

Abgrenzung von Informationssicherheit, IT-Sicherheit und Datenschutz

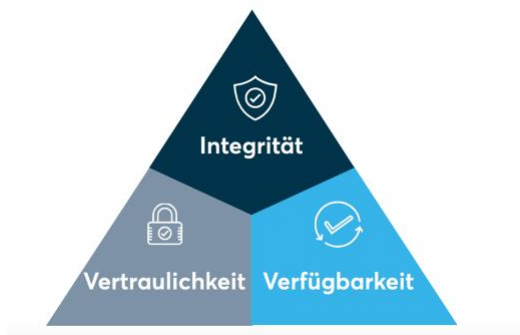


28

Unterschiede und Überschneidungen

- **Umfang:** Während Informationssicherheit alle Arten von Daten umfasst, konzentriert sich die IT-Sicherheit auf digitale Daten und Systeme. Cybersecurity hingegen bezieht sich auf das gesamte Spektrum des Internets und der Netzwerke.
- **Fokus:** Informationssicherheit hat ein breites Spektrum, IT Security ist stärker technologisch orientiert, und Cybersecurity beschäftigt sich mit Online-Bedrohungen und deren Management.

Schutzziele



- **Vertraulichkeit:** Informationen sind nur berechtigten Personen zugänglich
- **Integrität:** Informationen sind vor unrechtmäßiger oder außerplanmäßiger Veränderung gesichert
- **Verfügbarkeit:** Informationen sind zu jeder Zeit verfügbar und können bei Problemen wiederhergestellt werden

Warum Informationssicherheit wichtig ist und immer wichtiger wird

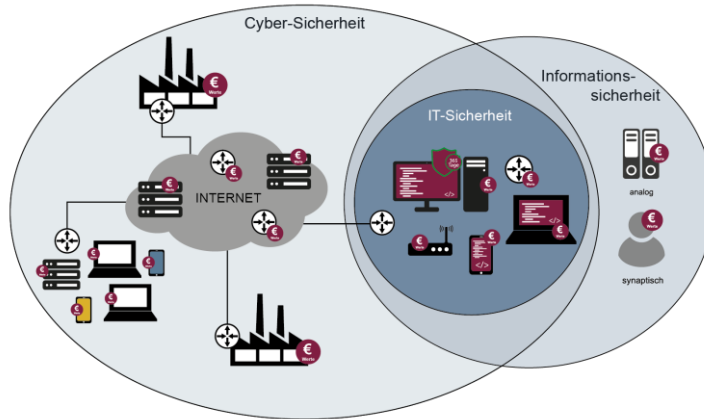
- **Weit verbreitete Bedrohungen** - Immer häufiger treten Informationssicherheitsbedrohungen, wie z. B. Würmer, Viren, digitale Erpressung, Diebstahl von geistigem Eigentum, Identitätsdiebstahl und Diebstahl physischer Ausrüstung auf.
- **Die Kosten von Datenschutzverstößen** - Datenschutzverstöße können unterschiedlich aussehen, doch alle können teuer werden, wenn eine Organisation sich nicht daran hält.
- **Von Staaten unterstützte Hacker** - Regierungen finanzieren Hackergruppen
- **Das Internet der Dinge** - Das Internet der Dinge ist ein riesiges Netzwerk aus physischen Gegenständen, die mit Software und Sensoren ausgestattet sind, mit denen sie sich mit dem Internet und anderen Geräten verbinden können.
- **Mehr Cyberattacken in schwierigen Zeiten** - Informationssicherheit ist immer wichtig, aber ganz besonders in Krisenzeiten.
- **Cyberangriffe immer ausgefeilter** - Cyberattacken werden immer ausgefeilter, und die Informationssicherheit damit noch wichtiger. Auch die Hacker werden besser und aufgrund der technologischen Fortschritte können sie mit weniger Anstrengungen eine größere Wirkung erzielen.

Welche Folgen kann „schlechte“ Informationssicherheit haben?

- **Betriebsstörungen:** Sogenannte Black-Hat-Hacker verlangen üblicherweise Lösegeld, wenn sie in die Systeme einer Organisation eindringen und auf deren Daten zugreifen.
- **Rechtliche Konsequenzen:** Wenn Partner, Kunden oder potenzielle Kunden von den Datenpannen betroffen sind, führt dies häufig zu Gerichtsprozessen.
 - geschwächtes Vertrauen der Kundschaft,
 - negative Schlagzeilen,
 - geringere Attraktivität für potenzielle Kunden,
 - saftige und unvorhergesehen Bußgelder.
- **Finanzieller Schaden:** Umsatzausfall, Gerichtskosten, Bußgelder, Bemühungen zur Eindämmung einer Cyberattacke oder einer Datenschutzlücke, Schadensersatzansprüche der Kunden sowie evtl. ein rückläufiger Aktienkurs (insbesondere bei börsennotierten Unternehmen).

IT-SICHERHEIT / SEMESTER 1 UND 2

Zusammenhang Cyber-Sicherheit, Informationssicherheit und IT-Sicherheit



[Quelle: <https://norbert-pohlmann.com/glossar-cyber-sicherheit/cyber-sicherheit-2/> -
letzter Abruf 04.05.2025]

tgm | Technologisches Gewerbemuseum | Höhere technische Bundes-Lehr- und Versuchsanstalt

33

33

02

Authentifizierung und Autorisierung

34

IT-SICHERHEIT / SEMESTER 1 UND 2

Du kommst hier nicht rein



tgm

[Quelle: <https://insights.mgm-tp.com/de/du-kommst-hier-nicht-rein/> - letzter Abruf 07.09.2025]

tgm | Technologisches Gewerbemuseum | Höhere technische Bundes-Lehr- und Versuchsanstalt

35

35

Authentisierung

36

Authentisierung

- Die Authentisierung stellt den **Nachweis einer Person dar**, dass sie tatsächlich diejenige Person ist, die sie vorgibt zu sein.
- Eine Person legt also **Nachweise** vor, die ihre Identität bestätigen sollen.
- Je nach der eingesetzten Authentisierungsmethode kann die Person ihre Identität unter anderem auf folgenden Wegen behaupten:
 - sie hat **geheime Informationen**, die nur ihr bekannt sind (z.B. Passwort)
 - sie **besitzt einen Identifizierungsgegenstand** (z.B. Personalausweis)
 - sie **ist selbst das Identifizierungsobjekt** (z.B. biometrische Merkmale wie Fingerabdruck).
- Kurz gesagt: Die Authentisierung stellt einen ersten Schritt zur Prüfung der Identität dar, indem eine Person aktiv eine bestimmte Identität behauptet.

Beispiel für Authentisierung

- Ein Fußball-Fan, nennen wir ihn Thomas, möchte das EM-Finalspiel 2016 live im Stade de France in Paris mitverfolgen.
- Hierfür hat sich Thomas für viel Geld ein personalisiertes Ticket bei einem Veranstalter gekauft.
- Am 10.07 steht er in der Schlange, um in das Stadium reinzukommen und hofft, dass er sich sogar in die VIP-Loge durchmogeln kann.
- Am Stadioneingang werden die Besucher nicht nur geprüft, ob sie ein gültiges Ticket haben, sondern stichprobenartig auch, ob der auf dem Ticket aufgedruckte Namen mit dem Besucher übereinstimmt.
- Thomas wird auserwählt und muss nicht nur sein Ticket sondern auch sein Personalausweis vorzeigen.
- Mit dem Vorzeigen des Personalausweises behauptet er zunächst „Thomas“ zu sein.

Klassen von Authentifizierungsverfahren - WISSEN



- **Nachweis der Kenntnis von Wissen um die Echtheit eines Nutzers zu überprüfen.**
- **Beispiele:** Passwort, PIN, Antwort auf eine bestimmte Frage (Sicherheitsfrage) usw.

Charakteristika von Wissen:

- Das Wissen kann vergessen werden (insbesondere nach einer Feier).
- Das Wissen kann dupliziert, verteilt, weitergegeben und verraten werden.
- Das Wissen kann in vielen Fällen erraten werden (Social Engineering, Wörterbuchangriff ...).
- Das Wissen kann beim Eintippen mitgelesen oder mithilfe eines Keyloggers (Malware) im Endgerät ausgelesen werden.
- Einmal abgefangenes Wissen gilt als kompromittiert, wenn es auch für weitere Dienste genutzt wird.
- Die Preisgabe von Wissen kann kompromittiert werden (Androhung von Gewalt).
- Die Mitführung von Wissen erfordert in der Regel keine praktischen Hilfsmittel.

Klassen von Authentifizierungsverfahren - BESITZ

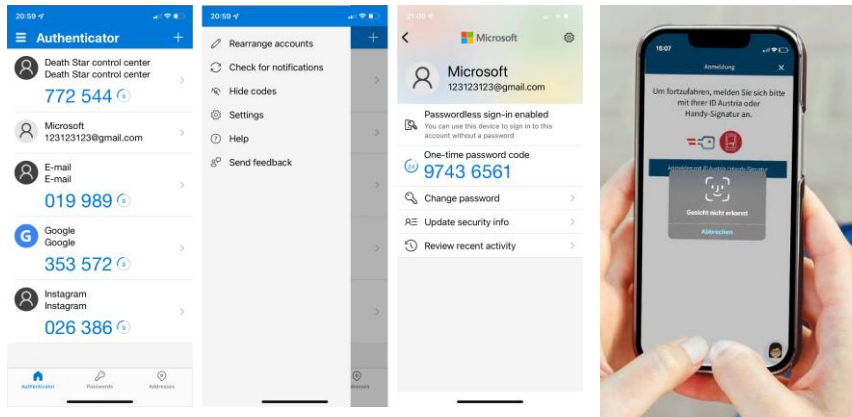


- **Verwendung eines Besitztums um die Echtheit eines Nutzers zu überprüfen.**
- **Beispiele:** Neuer Personalausweis (DE), SIM-Karte im Smartphone, Hardware-Sicherheitsmodule (Smartcard, USB-Stick, ...) usw.
- In der Regel wird der Besitz von geheimen Schlüsseln mithilfe von **Challenge-Response-Verfahren** nachgewiesen, die in den Sicherheitsmodulen sicher gespeichert sind.

Charakteristika von Besitz:

- Das Besitztum ist mit Kosten verbunden (Hardware).
- Das Besitztum muss mitgeführt werden (umständlich).
- Das Besitztum kann verloren gehen (kein Zugang mehr).
- Das Besitztum kann gestohlen werden (kein Zugang mehr).
- Das Besitztum kann übergeben oder weitergereicht werden (jemand anderes kann zugreifen).

Klassen von Authentifizierungsverfahren - BESITZ



41

Klassen von Authentifizierungsverfahren - SEIN



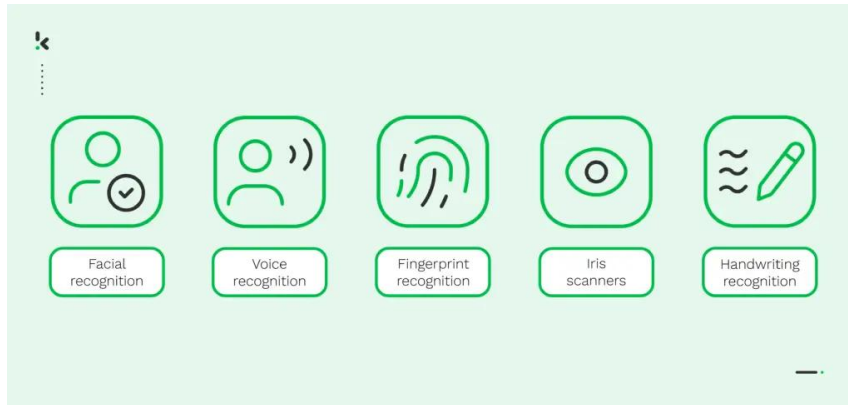
- **Gegenwart des Nutzers um die Echtheit eines Nutzers zu überprüfen.**
- **Beispiele:** Biometrische Merkmale wie Fingerabdruck, Gesichtsgeometrie, Iris, Tippverhalten, DNA usw.

Charakteristika von Sein:

- Biometrische Merkmale werden durch Personen immer mitgeführt.
- Biometrische Merkmale können nicht an andere Personen weitergegeben werden.
- Verfahren zur Erkennung von biometrischen Merkmalen können keine 100 %-Aussagen treffen, sondern nur mit einer gewissen Wahrscheinlichkeit die Echtheit von Personen abschätzen.
- Eine Lebenderkennung kann erforderlich sein (damit zum Beispiel ein künstlicher Fingerabdruck oder abgeschnittener Finger zurückgewiesen wird)
- Ein biometrisches Merkmal ist im Laufe der Zeit oder durch Unfälle veränderlich und damit schlechter erkennbar.
- Bestimmten Personengruppen fehlt das biometrische Merkmal.
- Ein biometrisches Merkmal kann nicht ersetzt werden (Problem, wenn diese „gestohlen“ werden können).

42

Klassen von Authentifizierungsverfahren - SEIN



Weitere unterstützende Faktoren



- **Beispiele:** Vergangene Transaktionen des Nutzers (Reputation), verwendete Endgeräte und Software des Nutzers (Technologie), Standort und Zeit des Authentisierungsprozesses.

Charakteristika weiterer unterstützender Faktoren:

- Die Reputation des Nutzers ist ein Indiz, wie er sich zukünftig verhalten wird.
- Die genutzte Technologie gibt einen Hinweis, ob es sich um den Nutzer handelt und wie das Angriffspotenzial des Endgeräts eingeschätzt werden kann.
- Der Standort gibt geografische und netzbasierte Informationen über das Vertrauensniveau des Orts (sichere oder unsichere Umgebung).

Authentifizierung

45

IT-SICHERHEIT / SEMESTER 1 UND 2

Authentifizierung

- Die Authentifizierung stellt eine **Prüfung der behaupteten Authentisierung** dar.
- Bei der Authentifizierung ist nun der Prüfer an der Reihe. Er überprüft die Angaben auf ihre Echtheit.
- Zeitlich betrachtet findet eine „Authentifizierung“ also nach einer „Authentisierung“ statt.



[Quelle: <https://www.dr-datenschutz.de/authentisierung-authentifizierung-und-autorisierung/> - letzter Abruf 07.09.2025]

tgm | Technologisches Gewerbemuseum | Höhere technische Bundes-Lehr- und Versuchsanstalt

46

46

Beispiel für Authentifizierung

- Nachdem sich Thomas mit seinem Personalausweis authentisiert hat, überprüft und bestätigt nun der Sicherheitsdienst seine Identität.
- Der freundliche Sicherheitsmitarbeiter schaut sich den Personalausweis genau an, ob der vor ihm stehende Thomas dem Foto im Personalausweis entspricht.
- Die Überprüfung der Identität ist hier die Authentifizierung.
- Das Ergebnis der Authentifizierung ist hier: entweder Thomas kommt rein oder nicht.

Arten der Authentifizierung

- Bei der **Single-Factor-Authentifizierung (SFA)** wird ein Authentifizierungsfaktor benötigt, um die Identität eines Benutzers nachzuweisen. Die Angabe eines Benutzernamens und eines Passworts für die Anmeldung bei einer Social-Media-Website ist ein typisches Beispiel für SFA.
- Die **Multi-Faktor-Authentifizierung (MFA)** erfordert mindestens zwei Authentifizierungsfaktoren von zwei verschiedenen Typen, wie z. B. ein Passwort (Wissensfaktor) und einen Fingerabdruckscan (inhärenter Faktor).
- Die **Zwei-Faktor-Authentifizierung (2FA)** ist ein spezieller Typ der MFA, der genau zwei Faktoren erfordert. Die meisten Internetnutzer haben bereits Erfahrung mit der 2FA gemacht, z. B. wenn eine Banking-App sowohl ein Passwort als auch einen Einmalcode erfordert, der an das Telefon des Benutzers gesendet wird.
- **Passwortlose Authentifizierungsmethoden** verwenden keine Passwörter oder andere Wissensfaktoren. Systeme ohne Passwort sind als Schutz vor Datendiebstahl beliebt geworden, da die Wissensfaktoren am einfachsten zu stehlen sind.
- **Adaptive Authentifizierungssysteme nutzen künstliche Intelligenz und maschinelles Lernen**, um die Authentifizierungsanforderungen je nach Risikograd des Benutzerverhaltens anzupassen. Ein Benutzer, der beispielsweise versucht, auf vertrauliche Daten zuzugreifen, muss möglicherweise mehrere Authentifizierungsfaktoren angeben, bevor das System diese bestätigt.

Beispiele für die Authentifizierung

- Mit einem Fingerabdruckscan und einem PIN-Code wird ein Smartphone entsperrt.
- Vorlage eines Ausweises zur Eröffnung eines neuen Bankkontos.
- Ein Webbrowser überprüft die Legitimität einer Website, indem er ihr digitales Zertifikat überprüft.
- Eine App verifiziert sich gegenüber einer Programmierschnittstelle (API), indem sie bei jedem Aufruf ihren geheimen API-Schlüssel mitsendet.

Autorisierung

Autorisierung

- Die Autorisierung ist die **Einräumung von speziellen Rechten**.
- War die Identifizierung einer Person erfolgreich, heißt es noch nicht automatisch, dass diese Person bereitgestellte Dienste und Leistungen nutzen darf.
- Darüber entscheidet die Autorisierung.

Beispiel für Autorisierung

- Der Sicherheitsmitarbeiter überprüft nun auch das Ticket von Thomas, um sicherzustellen, dass er im Besitz eines Tickets mit dem Zusatz VIP-Loge ist.
- Leider hat Thomas zwar ein gültiges Ticket für das Finalspiel jedoch keine Zusatzrechte, das Spiel in der VIP-Loge zu genießen.
- Er kommt zwar in das Stadion rein, ist aber nicht für den Besuch der VIP-Loge autorisiert.
- Hierfür fehlen ihm die zusätzlichen Rechte.

Beispiele für Autorisierung

- Wenn sich ein Benutzer bei seinem E-Mail-Konto anmeldet, kann er nur seine E-Mails sehen. Sie sind jedoch nicht berechtigt, die Nachrichten anderer Personen einzusehen.
- In einem Gesundheitsaktensystem können die Daten eines Patienten nur von Anbietern eingesehen werden, denen der Patient ausdrücklich seine Zustimmung erteilt hat.
- Ein Benutzer erstellt ein Dokument in einem gemeinsam genutzten Dateisystem. Sie setzen die Zugriffsberechtigungen auf „Nur lesen“, sodass andere Benutzer das Dokument zwar anzeigen, aber nicht bearbeiten können.
- Das Betriebssystem eines Laptops verhindert, dass ein unbekanntes Programm die Systemeinstellungen ändert.

Generelle Authentifikations- verfahren

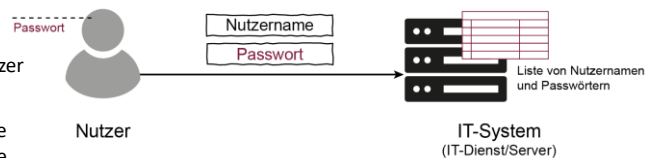
Generelle Authentifikationsverfahren

- Passwort-Verfahren
- Einmal-Passwort-Verfahren
- Challenge-Response-Verfahren
- Biometrische Verfahren

55

Passwort Verfahren

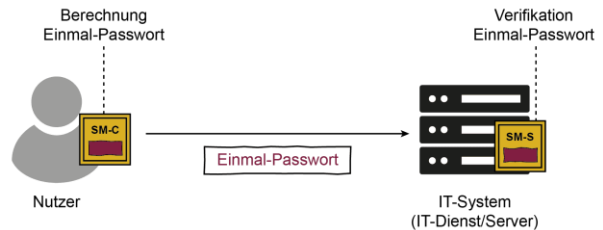
- Das **einfachste und prinzipiell unsicherste**, aber meist verwendete Authentifizierungsverfahren
- **Nutzername und ein Passwort** werden zwischen dem Nutzer und dem IT-System im Vorfeld abgesprochen.
- Der Nutzer weist dann beim Zugriff auf das IT-System seine **Identität (Nutzername)** nach, indem er das abgesprochene Passwort sendet.
- Das Passwort-Verfahren ist eine Authentifikation mit dem Nachweis der **Kenntnis von Wissen** – des Passworts.
- Das IT-System hat dazu eine **Liste von Nutzernamen und Passwörtern** von allen zugreifenden Nutzern zur Verfügung, um den Nachweis des Wissens überprüfen zu können.



56

Einmal-Passwort Verfahren

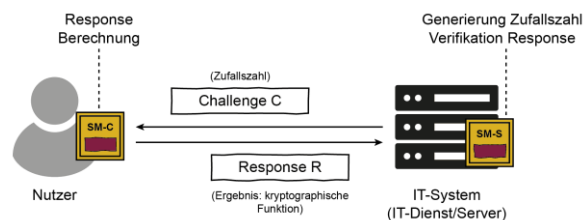
- Passwort kann nur **einmal für eine Session** benutzt werden.
- Damit wird ausgeschlossen, dass ein Angreifer ein Passwort abhören und erneut verwenden kann (**Replay-Attacken**).
- Ein **Man-in-the-Middle-Angriff (MITM)** ist aber immer noch möglich.
- Die Einmal-Passwörter werden in der Regel in einem **Hardware-Sicherheitsmodul** des Nutzers generiert.
- Die Verifikation findet in einem Hardware-Sicherheitsmodul des IT-Systems statt.
- Das Einmal-Passwort ist **nur für eine bestimmte Zeit nach der Generierung gültig**.



57

Challenge-Response-Verfahren

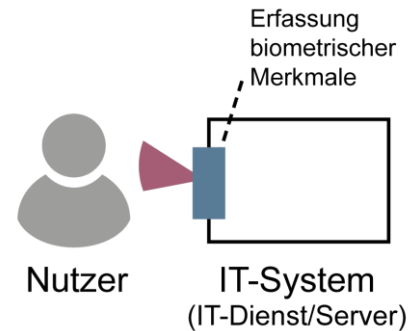
- Nutzer muss sich gegenüber dem IT-System **kryptografisch** beweisen muss.
- Bei diesem Verfahren besitzt der Nutzer ein **Geheimnis**, zum Beispiel einen geheimen Schlüssel, mit dem er als Beweis dafür, dass er den geheimen Schlüssel besitzt, spontan eine kryptografische Operation durchführen muss.
- In der Regel sendet das **IT-System dem Nutzer eine Zufallszahl**, die Challenge, die dann spontan kryptografisch verarbeitet und dem IT-System als Response gesendet wird.
- Das IT-System überprüft, ob der **Nutzer die kryptografische Operation richtig durchgeführt hat**.
- Aufgezeichnete Informationen können kein zweites Mal verwendet werden**, da immer neue Zufallszahlen als Challenge gesendet werden.
- Bei einer **Authentifizierung über unsichere Netze** müssen Challenge-Response-Verfahren eingesetzt werden, um ein Abhören und daraus resultierende missbräuchliche Verwendung zu verhindern.
- Für die Speicherung der geheimen Schlüssel und die Berechnung der kryptografischen Verfahren werden auf beiden Seiten **Hardware-Sicherheitsmodule** verwendet.



58

Biometrische Verfahren

- Authentifizierung **mittels biologischer Merkmale**.
- Biometrische Authentisierung verwendet **physiologische oder verhaltenstypische, also personengebundene Charakteristika**.
- Der prinzipielle Vorteil von biometrischen Verfahren für die Identifikation und Authentifizierung liegt darin, dass biometrische Merkmale **nicht unmittelbar gestohlen und im Allgemeinen nur schwer kopiert** werden können.
- Biometrische Merkmale können auf **viele Arten** gemessen werden z.B. Tippverhalten an einer Tastatur, die Fingergeometrie, das Fingerlängenverhältnis oder die Handgeometrie.
- Weitere Möglichkeiten sind Stimmanalyse, Gesichtserkennung, Erfassung der Unterschriftendynamik, des Netzhautmusters, des Irisusters oder des genetischen Codes



03

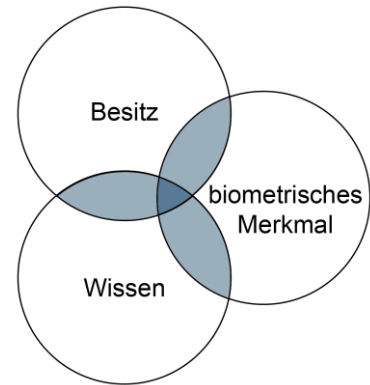
Multifaktor-Authentifizierung

Multifaktor-Authentifizierung

- Stand der Technik heute ist die Multifaktor-Authentifizierung.
- Mit einer Multifaktor-Authentifizierung (MFA) kann flexible agiert und mit einer höheren Vertrauenswürdigkeit authentifiziert werden.

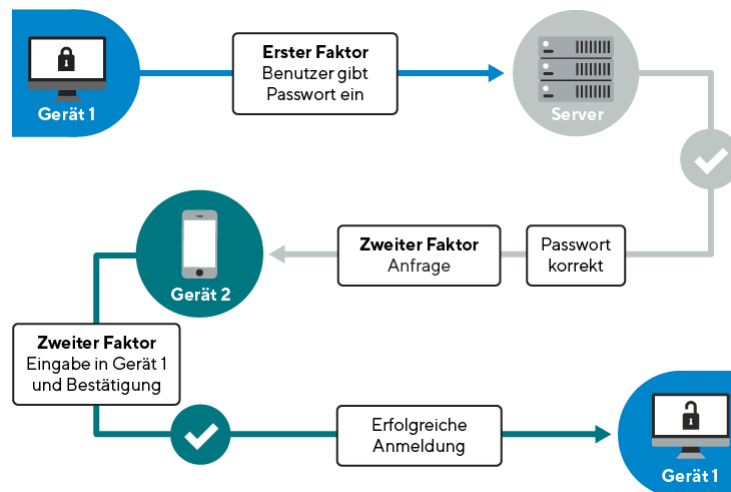
Beispiel Multifaktor-Authentifizierung:

- Es wird als **Basis eine digitale Signatur** einer Zufallszahl mithilfe eines Hardware-Sicherheitsmoduls (Smartcard, USB-Sick, ...) umgesetzt, das mit einem Passwort oder PIN aktiviert werden muss.
- Um den Nutzerbezug zu verstärken, muss der Nutzer noch mithilfe eines **Fingerabdrucks oder Gesichtserkennung seine Gegenwärtigkeit** zusätzlich verifizieren lassen.



61

So funktioniert die Zwei-Faktor Authentifizierung



62

Welche MFA-Verfahren sich für die Implementierung anbieten



Authentifizierungs-Apps

Apps wie der Microsoft Authenticator und der Google Authenticator generieren zeitbasierte Einmalpasswörter (engl. Time-based one-time password, kurz: TOTP), die beispielsweise ergänzend zu der klassischen Kombination aus Nutzernamen und Passwort eingesetzt werden können. Die App von Microsoft unterstützt außerdem auch Push-Benachrichtigungen und Biometrie. User müssen ein Smartphone zur Hand haben, um solche Authenticator-Apps zu nutzen.



SMS-Authentifizierung

Bei der SMS-Authentifizierung schickt das System an den Nutzer zur Anmeldung eine einmalige Bestätigungsnummer – die SMS TAN bzw. PIN. Erst nach Eingabe des erhaltenen Codes ist die Anmeldung abgeschlossen. Das Verfahren ist einfach und weit verbreitet, kann jedoch aus der Ferne kompromittiert werden und ist weniger sicher als der Einsatz von Authenticator-Apps und FIDO2.



FIDO2 Key

FIDO steht für Fast Identity Online und ist ein offener Standard für sichere Authentifizierung im Internet. Ein FIDO2-Schlüssel ist ein physisches Gerät – meist in Form eines Schlüsselanhängers. Die Token sind für weniger als 30 Euro erhältlich. FIDO2 kann die gängige Benutzernamen-Passwort-Anmeldung um einen weiteren Faktor mit dem FIDO2-Token ergänzen und auch für eine komplett passwortlose Anmeldung eingesetzt werden.

Wo kommen diese Sicherheitsverfahren zum Einsatz?

- **Online-Banking:** Anmeldung mit Passwort und Bestätigung von Transaktionen zusätzlich mit TAN via mTAN oder pushTAN, alternativ auch kartenbasierte Systeme wie chipTAN oder HBCI.
- **Debit- oder Kreditkartenzahlung:** Der Chip in der Karte zeigt den Besitz an und das Wissen der PIN legitimiert den Vorgang.
- **Online-Ausweisfunktion des Personalausweises (DE):** Zur Datenübermittlung muss der Chip im Ausweis durch Eingabe der PIN zunächst freigegeben werden. Zusätzlich findet eine gegenseitige Authentisierung zwischen Ausweis und Diensteanbieter statt und die ausgelesenen Daten werden Ende-zu-Ende-verschlüsselt zum Diensteanbieter übertragen.
- **Cloud- oder E-Mail-Anbieter, Social Media Plattformen:** Sicherer Login mit Passwort und mTAN oder einem OTP aus einer Authenticator-App, alternativ auch hardwarebasiert mit einem U2F/FIDO-Token.
- **Steuererklärung:** Mit finanzonline kann die Steuererklärung digital eingereicht werden, die Anmeldung erfolgt mit der ID-Austria.
- ...

Bitte nicht: Die Zwei-Faktor-Authentisierung deaktivieren

- Einen Online-Account ausreichend abzusichern, ist manchmal unbequem.
- In jedem Fall ist davon abzuraten, die Zwei-Faktor-Authentisierung zu deaktivieren.
- **Sobald dies bei einem Online-Dienst möglich ist, sollte man sie anwenden.**
- Gerade beim Online-Banking, dem Online-Shopping und bei Accounts mit weitreichenden Rechten und Möglichkeiten (z.B. E-Mail und Social Media) lohnt sich das Mehr an Sicherheit.
- Identitätsdiebstahl, fremde Accountübernahmen oder die Veröffentlichung sensibler Daten müssen also nicht sein.

Aktuelle Empfehlungen und Risiken

Empfehlungen

- Wenden Sie eine Zwei-Faktor-Authentisierung an, sobald ein Online-Dienst dies ermöglicht.
- Viele Dienste haben die Funktion standardmäßig deaktiviert, bieten sie aber dennoch an. Eine Überprüfung der Login-Verfahren lohnt sich.
- Gelangt Ihr Passwort oder Ihre PIN in die falschen Hände, sind Ihre sensiblen Daten dennoch gut gesichert, wenn sie durch die weitere Barriere eines zweiten Faktors vor fremdem Zugriff abgesichert werden.

Nachteile

- Eine Mehrfaktor-Authentisierung verlängert den Anmeldevorgang geringfügig. Auf vertrauenswürdigen Geräten kann sie zwar unter Umständen übersprungen werden, dies verringert aber die Sicherheit.
- Wenn Sie keinen Zugriff auf Ihren besitzbasierten Faktor mehr haben oder er kaputt geht, verlieren Sie in der Regel den Zugang zum entsprechenden Dienst oder seine Funktionalität wird eingeschränkt. Sorgen Sie für diesen Fall vor, indem Sie – wenn möglich – mehrere "zweite Faktoren" hinterlegen (z.B. ein weiteres Token, eine weitere TAN-App oder eine weitere Mobiltelefonnummer für mTAN).